Financial / FINRA Communications Compliance — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Financial / FINRA Communications Compliance (Microsoft Purview) 5

The problem . . . 5

The solution . . . 5

What's included . . . 5

Why it matters . . . 5

What stays with the firm . . . 6

1. Solution Overview — Financial / FINRA Communications Compliance (Microsoft Purview) 6

What this solution is . . . 6

Why this matters . . . 7

How it works . . . 7

The three pillars, mapped to the deliverables . . . 8

What you get . . . 8

Scope and boundaries . . . 9

2. Requirements Guide — Financial / FINRA Communications Compliance (Microsoft Purview) 9

2.1 Communication Compliance entitlement (E5 / E5 Compliance) . . . 9

2.2 Designated supervisory principals and role separation . . . 10

2.3 Approved supervised population and exclusions (registered persons) . . . 10

2.4 Firm conduct lexicons and Written Supervisory Procedures (WSPs) . . . 10

2.5 Channels and connected communication sources in scope . . . 11

2.6 Records-retention schedule and immutability decision (evidence layer) . . . 11

2.7 Privacy configuration and legal basis . . . 11

2.8 Change control, pilot scope, and rollback authority . . . 12

Global Requirements — Microsoft Purview Solutions 13

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 14

3. Implementation Guide — Financial / FINRA Communications Compliance (Microsoft Purview) 15

Step 1 — Confirm readiness and capture the baseline (Assess) . . . 16

Step 2 — Configure privacy, role separation, and scope FIRST (Configure — guardrails) . . . 16

Step 3 — Design the supervision policy from the WSPs and lexicons (Design) . . . 17

Step 4 — Build the policy in SIMULATION/TEST (Configure — pilot-first) . . . 17

Step 5 — Validate detection with test communications (Pilot / Validate — lexicons) . . . 18
Step 6 — Exercise the designated-principal review workflow (Pilot / Validate — review) . . . 18
Step 7 — Configure the immutable retention evidence layer (Configure — evidence) . . . 18
Step 8 — Tune, then expand under change control (Validate → Expand/enforce) . . . 19
Rollback summary . . . 19
5. Testing & Validation Guide — Financial / FINRA Communications Compliance (Microsoft Purview) 20
A. Role separation and privacy (guardrails) . . . 20
B. Scope (supervised population) . . . 21
C. Lexicons (detection) . . . 21
D. Review (workflow) . . . 22
E. Evidence (retention / recordkeeping) . . . 22
Pilot exit criteria (all must pass before expansion) . . . 23
6. Troubleshooting Guide — Financial / FINRA Communications Compliance (Microsoft Purview) 23
A. Entitlement, portal, and classifiers . . . 23
B. Role separation . . . 24
C. Scope and privacy . . . 25
D. Detection (lexicons) . . . 25
E. Review workflow . . . 25
F. Evidence (retention / immutability) . . . 26
7. Best Practices — Financial / FINRA Communications Compliance (Microsoft Purview) 27
Program design . . . 27
Role separation and privacy . . . 27
Lexicons and detection tuning . . . 27
Review workflow . . . 28
Evidence and recordkeeping . . . 28
Change control and rollout . . . 28
Operations . . . 29
8. Deliverables Summary — Financial / FINRA Communications Compliance (Microsoft Purview) 29
What this solution delivers . . . 29
Documents . . . 29
PowerShell tools (5) . . . 30
Named artifacts created/used . . . 31
Definition of done . . . 31
Explicitly deferred (not in this solution) . . . 31

Appendix A — PowerShell Scripts 33

Executive Summary — Financial / FINRA Communications Compliance (Microsoft Purview)

The problem

Regulated financial firms have an affirmative **duty to supervise** their registered persons' communications and to **preserve** those communications as books & records. Both obligations are routinely examined, and gaps in either — no supervision program, an undocumented review, or communications that weren't retained in a tamper-evident form — are a common and costly source of enforcement. Doing this manually doesn't scale; doing it carelessly creates its own privacy and employment liability.

The solution

This solution stands up a **FINRA/SEC-aligned communications-supervision program** on Microsoft Purview Communication Compliance — using tooling most regulated firms **already own** through Microsoft 365 E5 / E5 Compliance. It is organized around the three pillars an examiner looks for:

- **Lexicons** — regulated-conduct detection: Purview trainable classifiers (money laundering, market manipulation, unauthorized disclosure, gifts & entertainment, customer complaints, and more) plus the firm's own **keyword lexicons**, scoped to the registered/supervised population.
- **Review** — a **designated-principal**, risk-based-sample supervisory workflow with tag / escalate / resolve and a **defensible reviewer trail** — the reasonable-supervision mechanic.
- **Evidence** — **immutable communications retention** and examiner-ready reporting, so the messages and the fact-of-review are preserved, tamper-evident, and producible on request.

Everything is **piloted in simulation/test first**, validated against explicit pass/fail gates, and expanded in rings under change control — no firm-wide switch flipped blind.

What's included

- Seven implementation documents (overview, requirements, step-by-step implementation, testing, troubleshooting, best practices, deliverables summary) plus this executive summary.
- **Five PowerShell tools** (discovery, configuration, validation, reporting, evidence/scope health) — **read-only or** `-WhatIf` **by default**, no credentials in code.

Why it matters

- **Defensible, not just detective.** The value is in the guardrails, the documented review, and the tamper-evident evidence — not just a keyword alert. This program produces the record that demonstrates reasonable supervision.
- **Privacy- and separation-first.** Reviewers are separated from those they supervise, scope is the

approved registered population (not "everyone"), and pseudonymization is available where required.

- **Lower cost, faster.** Self-guided steps and tested tooling deliver a program in a fraction of the time and cost of a bespoke consulting engagement, on platform you already license.

What stays with the firm

The **regulatory determination** (which rules apply, whether a communication violates them), the **retention schedule and immutability decision**, and any **supervisory or disciplinary action** remain with the firm's **designated supervisory principals, Compliance, Records, and Legal**. This solution delivers the **technical supervision-and-evidence mechanism** — configured, piloted, validated, and defensible.

Bottom line: Meet FINRA/SEC communications supervision — delivered, validated, and defensible in Microsoft Purview.

1. Solution Overview — Financial / FINRA Communications Compliance (Microsoft Purview)

What this solution is

This solution stands up a **FINRA/SEC-aligned communications supervision program** on top of Microsoft Purview **Communication Compliance**, tuned specifically for **regulated financial firms** (broker-dealers, RIAs, and their affiliates). Where a general communication-compliance deployment watches for harassment, threats, and data leaks, this program is built for the **regulatory conduct duty**: supervising registered-person communications for **money-laundering, market-manipulation, unauthorized-disclosure, insider-trading, guarantees/misrepresentation, gifts & entertainment, selling away, and customer-complaint** signals, and — just as importantly — **evidencing** that the supervision happened and preserving the underlying communications so the program is **defensible to a regulator**.

The program is organized around three pillars that match the way a financial-firm supervision program is examined:

1. **Lexicons** — the detection layer: Purview **trainable classifiers** for regulated conduct plus **custom keyword dictionaries ("lexicons")** encoding the firm's own prohibited-conduct language, attached to a supervisory-review policy scoped to the **registered/supervised population**.
1. **Review** — the supervisory workflow: **designated principals** (reviewers separated from the people they supervise) triage flagged items on a **risk-based sample**, tag/escalate/resolve them, and leave a defensible reviewer trail — the Rule 3110 "reasonable supervision" mechanic.
1. **Evidence** — the recordkeeping layer: an **immutable retention** configuration over the supervised communications and the review activity, so the messages and the fact-of-review are **preserved and tamper-evident** (the SEC Rule 17a-4 style "books & records" posture) and producible on request.

It uses only the **Microsoft Purview portal** (`purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`; the `SupervisoryReview*` and `RetentionCompliance*` cmdlets), and **Microsoft Graph** — no third-party archiving/surveillance tooling.

> ***Reference vs this solution.*** *A separate solution covers* ***general Communication Compliance*** *(the broad harassment / offensive-language / data-leak use of the same Purview capability).* ***This solution is the financial-regulatory specialization****: the same engine, but scoped to the registered population, driven by* ***regulated-conduct classifiers and firm lexicons****, wrapped in a* ***designated- principal supervisory-review workflow****, and paired with an* ***immutable communications-retention evidence layer****. If you only need general offensive-language monitoring, use the general solution; if you must demonstrate a* ***FINRA/SEC communications-supervision program****, use this one.*
>
> ***This is the technical program, not the regulatory determination.*** *The solution configures the mechanism — detection, review workflow, and preservation — and produces the evidence.* ***What language constitutes a violation, which rules apply to which persons, what the retention period must be, and what supervisory action to take are determinations for the firm's Compliance, Legal, and designated supervisory principals*** *under the firm's Written Supervisory Procedures (WSPs) — never for IT and never for the tool.*

Why this matters

• Regulated financial firms have an affirmative **duty to supervise** the communications of their

registered persons (FINRA Rule 3110 / supervisory-controls obligations) and to **preserve** those communications as books & records (SEC Rule 17a-4 / 17a-3, FINRA Rule 4511). Both the supervision and the recordkeeping are routinely examined, and gaps in either are a common cause of enforcement.

• Doing this **manually doesn't scale** and doing it **carelessly creates liability**: reviewing every

message is impossible, but an undocumented or unpreserved review is treated as no review at all. A defensible program needs **risk-based sampling, a designated-principal workflow, and tamper-evident evidence** — not just a keyword alert.

• Supervision is **privacy- and conduct-sensitive**. The people who *review* must be **separated** from

the people they supervise; reviewers must not be able to quietly change what they were required to look at; and the supervised scope must be the **approved registered population**, not "everyone."

• **Outcomes are a Compliance/Legal determination.** The program surfaces and preserves potentially

problematic communications and records the supervisory review; **whether a communication actually violates a rule, and what happens next, is decided by the firm's supervisory principals, Compliance, and Legal** — the tooling provides the method and the evidence, not the verdict.

How it works

1. **Role separation and the supervised scope are established first.** The Communication Compliance

role groups (Admin / Analysts / Investigators / Viewers) are populated so the **policy-builders**, the **designated-principal reviewers**, the **escalation/investigation** handlers, and **oversight** are separated — agreed with Compliance and Legal. The supervised population is the **approved registered persons**, with an explicit **exclusion** set.

1. **A supervisory-review policy names the scope, the reviewers, and the channels.** The policy names

the **supervised registered persons**, the **designated principals** who will review its items, and the **channels** inspected (Teams chat/channels, Exchange email, Viva Engage, and — where licensed and connected via Microsoft 365 data connectors — approved third-party sources).

1. **Lexicons + classifiers define what to surface.** Rules attach **regulated-conduct trainable

classifiers **(money laundering, stock/market manipulation, unauthorized disclosure, regulatory collusion, gifts & entertainment, customer complaints — *availability is plan-dependent and some are in preview; verify in your tenant*), the firm's** custom keyword dictionaries (lexicons)**, sensitive information types, and conditions — plus a** risk-based sampling percentage**.

1. **The policy runs first in SIMULATION/TEST.** It is built narrow, validated, and tuned in a pilot

scope before any broad rollout — the category's **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** model. High-impact supervision is never switched on firm-wide blind.

1. **Designated principals review on a risk-based sample.** Reviewers triage flagged items, tag them

(compliant / questionable / non-compliant), add notes, resolve, or **escalate** to an investigator — producing the defensible reviewer trail that demonstrates reasonable supervision.

1. **The communications and the review are preserved as evidence.** An **immutable retention**

configuration (retention policy/labels with **Preservation Lock** where the firm's records schedule requires it) preserves the supervised communications and the review activity in a **tamper-evident** form, and the program's reporting rolls the activity up for examiners — the "evidence" pillar. **The retention period and lock decision are set by Compliance/Records, not by IT.**

The three pillars, mapped to the deliverables

Pillar	What it delivers	Where it lives
Lexicons	Regulated-conduct classifiers + firm keyword dictionaries on a scoped supervisory-review policy	Implementation Steps 3–5; `CCFIN-Configuration.ps1`
Review	Designated-principal, risk-based-sample review workflow with tag/escalate/resolve and a defensible trail	Implementation Steps 2, 6; `CCFIN-Report.ps1`
Evidence	Immutable communications retention (17a-4 posture) + review-activity reporting, tamper-evident and producible	Implementation Step 7; `CCFIN-EvidenceCheck.ps1`, `CCFIN-Report.ps1`

What you get

• This **Solution Overview**, a **Requirements Guide**, a step-by-step **Implementation Guide**, a

Testing/validation guide, a **Troubleshooting** guide, a **Best Practices** guide, and a **Deliverables Summary**.

• **Five PowerShell tools** — Discovery, Configuration (simulation/`-WhatIf` first), Validation,

Reporting, and an Evidence/scope health helper — all **read-only or** `-WhatIf` **by default**, with no credentials in code.

Scope and boundaries

• **In scope:** designing and configuring a FINRA/SEC-aligned communications-supervision program in Microsoft Purview Communication Compliance — role separation, supervised scope, regulated-conduct classifiers and firm lexicons, the designated-principal review workflow, immutable communications retention for evidence, and pass/fail validation.

• **Out of scope (deferred to the firm's governance functions):** the **regulatory determination** of which rules apply and whether a communication violates them (Compliance/Legal/supervisory principals); the **retention schedule and lock decision** (Compliance/Records); **disciplinary or regulatory action** (Compliance/Legal/HR); trade surveillance and order/execution monitoring (a different discipline); and any third-party archiving product. This solution delivers the **technical supervision-and-evidence mechanism**, configured, piloted, and validated.

2. Requirements Guide — Financial / FINRA Communications Compliance (Microsoft Purview)

Confirm each item **before** starting the Implementation steps. These are **in addition to** the six shared prerequisites in `global-requirements-purview.md` (tenant/licensing, least-privilege Purview roles, Security & Compliance PowerShell + Graph toolchain, in-scope data sources, compliance/records/ legal stakeholders, and a pilot scope + change control) — that file is the baseline and is **not** repeated here. The requirements below are the ones **specific to a FINRA/SEC communications-supervision program**.

Each requirement is stated as **Description · Why required · How to verify · How to implement**. Purview features are **licensing-/plan-dependent and some are in preview**, and the portal evolves — where noted, **verify availability against your own tenant and Microsoft licensing; do not assume.**

2.1 Communication Compliance entitlement (E5 / E5 Compliance)

• **Description:** The **Communication Compliance** capability must be licensed and visible in the Purview portal. It is part of **Microsoft 365 E5** / the **E5 Compliance** add-on (or equivalent); several **regulated-conduct trainable classifiers** are separately gated and **some are in preview**.

• **Why required:** Without the entitlement, the supervisory-review area and the regulated-conduct classifiers this program relies on are unavailable.

• **How to verify:** Purview portal → **Communication Compliance** is present and openable; in `Settings` the policy/classifier options load. **Confirm the exact entitlement with Microsoft licensing — do not assume from portal visibility alone.**

• **How to implement if missing:** Assign/purchase the required licensing (GR §1) before configuring; flag any classifier shown as *preview* for a licensing/risk check with Compliance.

2.2 Designated supervisory principals and role separation

• **Description:** The people who will **review** supervised communications must be **designated

supervisory principals **(per the firm's WSPs), placed in the** Communication Compliance Analysts **role, and** separated **from the** Admin **(policy builders),** Investigators **(escalation), and** Viewers** (oversight, reports-only) — and separated from the population they supervise.

• **Why required:** FINRA supervision requires review **by an appropriately qualified person who is not

supervising themselves**; collapsing builder/reviewer/subject into one identity undermines both the control and its defensibility.

• **How to verify:** Purview portal → `Settings → Roles & scopes → Permissions` — confirm the four role

groups exist and membership is separated; `CCFIN-Discovery.ps1` prints the separation snapshot.

• **How to implement if missing:** With Compliance/Legal, assign designated principals to **Analysts**,

keep IT config staff in **Admin**, and record who may **not** review whom. Avoid the combined **Communication Compliance** role group except for a tiny pilot (it collapses separation).

2.3 Approved supervised population and exclusions (registered persons)

• **Description:** The **supervised population** must be the **approved registered/covered persons**

(typically registered representatives, principals, and associated persons the firm's WSPs place under communications supervision), expressed as a group, with an explicit **exclusion** set for anyone who must not be monitored.

• **Why required:** Supervision scope is a **compliance determination**, not "everyone"; over-scoping is

a privacy and works-council/employment risk, under-scoping is a supervision gap.

• **How to verify:** Confirm the named supervised group and exclusion group with Compliance;

`CCFIN-EvidenceCheck.ps1` reports the policy's supervised/excluded scope.

• **How to implement if missing:** Have Compliance define the registered/covered population; create the

supervised group (`FINRA Supervised – Pilot` for the pilot) and the exclusion group (`FINRA Excluded – Privacy`).

2.4 Firm conduct lexicons and Written Supervisory Procedures (WSPs)

• **Description:** The firm's **prohibited-conduct language** (guarantees, misrepresentation, selling

away, unregistered activity, undisclosed outside business, complaint language, etc.) as **keyword dictionaries ("lexicons")**, plus the **WSPs** that define what is supervised, at what sampling rate, and by whom.

• **Why required:** Detection is only as good as the firm's own lexicon; the WSPs are the authority for

scope, sampling, and reviewer assignment — the tool implements them, it does not invent them.

• **How to verify:** Compliance provides the lexicon term lists and the current WSP supervision section;

confirm the sampling rate and reviewer mapping are documented.

• **How to implement if missing:** Have Compliance supply the lexicon(s) and the WSP supervision requirements before building any rule; capture them as the `FINRA Lexicon – Conduct` dictionary and the policy sampling/reviewer design.

2.5 Channels and connected communication sources in scope

• **Description:** The **communication channels** to supervise — Teams chat/channels, Exchange email, Viva Engage, and any **third-party sources** (e.g. text/IM, social, or trading-desk chat) ingested via **Microsoft 365 data connectors** — and confirmation each in-scope source is actually flowing.

• **Why required:** A supervision program that omits a channel registered persons use (e.g. text/IM) is a known examination finding; connectors must be **configured and verified**, not assumed.

• **How to verify:** Purview portal → **Data connectors** shows the required connectors healthy; confirm Teams/Exchange/Viva Engage coverage with the messaging owners.

• **How to implement if missing:** Stand up and validate the required data connectors (a prerequisite project where third-party sources are in scope), then include those sources in the policy.

2.6 Records-retention schedule and immutability decision (evidence layer)

• **Description:** The **retention period** for supervised communications and review activity, and whether **immutability/Preservation Lock** is required — the firm's **books-&-records** decision (SEC Rule 17a-4 / FINRA Rule 4511 territory), owned by **Compliance/Records**.

• **Why required:** The evidence pillar preserves communications and review activity; the **period and the lock are a records determination**.** Preservation Lock is irreversible** — it must be an approved, deliberate decision, not a technical default.

• **How to verify:** Compliance/Records provides the retention period and states whether immutability is required; `CCFIN-EvidenceCheck.ps1` reports current retention/immutability coverage.

• **How to implement if missing:** Do **not** apply any lock until Compliance/Records has approved the schedule and the immutability decision in writing; configure retention accordingly (Implementation Step 7).

2.7 Privacy configuration and legal basis

• **Description:** The agreed **privacy option** for the review experience (e.g. **pseudonymized usernames **where the firm's privacy/works-council posture requires it) and a documented** lawful basis / notice** for supervising employee communications.

• **Why required:** Supervision touches employee privacy; several jurisdictions and works councils require pseudonymization and/or notice, and reviewer over-reach is itself a risk.

• **How to verify:** Privacy/Legal states the required privacy option and confirms notice/lawful basis;

the setting is checked in `Settings → Communication Compliance`.

• **How to implement if missing:** Set the agreed privacy option before any policy runs; do not go live without Privacy/Legal sign-off on the lawful basis.

2.8 Change control, pilot scope, and rollback authority

• **Description:** A named **pilot scope** (the `FINRA Supervised – Pilot` population, in **simulation/test**), a **change window/approval**, and clear **rollback** authority for each stage.

• **Why required:** Supervision and retention changes are high-impact; the category model mandates **pilot-in-simulation-first** with explicit pass/fail gates and documented rollback.

• **How to verify:** Confirm the pilot population, that simulation mode is available for the policy, the approval path, and who may authorize rollback.

• **How to implement if missing:** Define the pilot and change control before enforcing anything; agree that retention **Preservation Lock** has a separate, explicit approval (it cannot be rolled back).

Requirements summary

#	Requirement	Verify with
2.1	Communication Compliance entitlement (E5 / E5 Compliance; some classifiers preview)	Portal + Microsoft licensing
2.2	Designated principals + role separation	Roles & scopes; `CCFIN-Discovery.ps1`
2.3	Approved supervised population + exclusions	Compliance; `CCFIN-EvidenceCheck.ps1`
2.4	Firm conduct lexicons + WSPs	Compliance-supplied term lists / WSP
2.5	Channels + connected sources in scope	Data connectors; messaging owners
2.6	Retention schedule + immutability decision	Compliance/Records; `CCFIN-EvidenceCheck.ps1`
2.7	Privacy option + lawful basis	Privacy/Legal; portal settings
2.8	Change control, pilot scope, rollback	Change management

*Regulatory applicability, what constitutes a violation, the retention schedule, the immutability decision, and any supervisory/disciplinary action are **deferred to Compliance, Records, Legal, and the firm's designated supervisory principals** — this solution provides the technical method and the evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Financial / FINRA Communications Compliance (Microsoft Purview)

Follow these steps **in order**. Configuration is done in the **Microsoft Purview portal** (`https://purview.microsoft.com` → **Communication Compliance**) and, where automated, via **Security & Compliance PowerShell** (`Connect-IPPSSession`; Communication Compliance is backed by the `SupervisoryReview*` cmdlets, the evidence layer by the `RetentionCompliance*` cmdlets) and **Microsoft Graph**. Artifact names follow the `FINRA <Purpose> – <Scope> – <Stage>` convention below and are reused verbatim by the scripts and tests. **Portal paths, cmdlets, and classifier availability are plan-dependent and the portal evolves — verify against your tenant; some classifiers are in preview.**

> ***Model:*** *Establish **role separation + supervised scope + privacy first**, design the policy from the firm's WSPs and lexicons, build it in **SIMULATION/TEST**, validate detection + the designated-principal review workflow + privacy + evidence, tune, then expand — and configure the **immutable retention evidence layer** under Compliance/Records approval. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce). Outcomes and the retention/immutability decision are deferred to Compliance/Records/Legal and the firm's supervisory principals at every step** — this guide configures the mechanism, not the verdict.*

Named artifacts (created/used across the steps)

Artifact	Name	Purpose
Supervised pilot group	`FINRA Supervised – Pilot`	The approved registered/covered persons in the pilot
Exclusion group	`FINRA Excluded – Privacy`	Anyone who must never be supervised
Reviewers group	`FINRA Principals – Pilot`	Designated supervisory principals (Analysts)
Keyword dictionary	`FINRA Lexicon – Conduct`	The firm's prohibited-conduct terms
Policy	`FINRA Supervision – Pilot – Simulation`	The supervisory-review policy (simulation-first)
Rule	`FINRA Conduct Rule – Pilot`	Classifiers/lexicon/conditions + sampling

Artifact	Name	Purpose
Retention policy	`FINRA Comms Records – 17a-4`	Immutable evidence retention (evidence layer)
Evidence snapshots	`FINRA Supervision Roles – Evidence`, `FINRA Supervision Rollup – Evidence`	Separation + review-activity evidence

Step 1 — Confirm readiness and capture the baseline (Assess)

1. Confirm the **Communication Compliance** area is visible in the Purview portal (Requirement 2.1).

Verify the entitlement with Microsoft licensing — do not assume from visibility. Note any regulated-conduct classifier shown as *preview*.

1. Run `CCFIN-Discovery.ps1` (read-only). It reports the readiness signals it can see: membership of each Communication Compliance role group (the **role-separation snapshot**, `FINRA Supervision Roles – Evidence`), any existing supervisory-review policies/rules, retention policies that already cover communications, and privacy/scope signals — flagging over-broad scope or collapsed separation.

1. **Pass/fail gate:** entitlement present, the four role groups exist, and you have a clear picture of current membership, policies, and retention coverage. **Do not proceed** until Compliance/Legal have approved the supervised population, the designated principals, the sampling rate, and the lawful basis (Requirements 2.2–2.4, 2.7). Fail → resolve before configuring.

Step 2 — Configure privacy, role separation, and scope FIRST (Configure — guardrails)

1. Portal → `Settings → Communication Compliance` (Privacy): set the agreed **privacy option** — enable **pseudonymized usernames** in the review experience if Privacy/Legal require it (Requirement 2.7).

1. Portal → `Settings → Roles & scopes → Permissions`: populate the role groups **with separation** (Requirement 2.2):

- **Communication Compliance Admin** → IT/program config staff who *build* policies.
- **Communication Compliance Analysts** → the **designated supervisory principals** (`FINRA Principals – Pilot`) who *review* items.
- **Communication Compliance Investigators** → the Compliance/Legal **escalation** handlers.
- **Communication Compliance Viewers** → oversight (reports only, **no content**).

Avoid the combined **Communication Compliance** role group outside a tiny pilot — it collapses separation.

1. Create/confirm the **supervised** group `FINRA Supervised – Pilot` (the **minimum approved**

registered population) and the **exclusion** group `FINRA Excluded – Privacy` (Requirement 2.3).

1. **Pass/fail gate:** privacy setting matches Privacy/Legal's decision; role membership is separated (no

one is silently both builder and reviewer, and **no reviewer supervises themselves**); the supervised and excluded groups exist and are approved. Re-run `CCFIN-Discovery.ps1` and confirm the snapshot reflects the intended separation. **Rollback:** remove any mistaken role-group membership — separation errors are corrected here, before any policy exists.

Step 3 — Design the supervision policy from the WSPs and lexicons (Design)

1. With Compliance, translate the **WSP supervision section** (Requirement 2.4) into concrete detection:

which **regulated-conduct trainable classifiers** to use — e.g. **Money laundering, Stock/market manipulation, Unauthorized disclosure, Regulatory collusion, Gifts & entertainment, Customer complaints** (*availability plan-dependent; some in preview — verify in your tenant*).

1. Capture the firm's prohibited-conduct terms as the **keyword dictionary (lexicon)** `FINRA Lexicon –

Conduct` — guarantees/"can't lose", selling-away, undisclosed-outside-business, unregistered-activity, and complaint language the firm wants surfaced. **Compliance supplies the terms; do not invent them.**

1. Add any **sensitive information types** for data-leak detection (e.g. account/SSN patterns), and

define **conditions** (direction, attachments, message size) and the **risk-based sampling percentage** from the WSPs.

1. Confirm the **channels** in scope (Teams / Exchange / Viva Engage / connected sources — Requirement

2.5) and the **reviewers** (`FINRA Principals – Pilot`, from Analysts).

1. Record the design as `FINRA Supervision – Pilot – Simulation` with rule `FINRA Conduct Rule – Pilot`.

Step 4 — Build the policy in SIMULATION/TEST (Configure — pilot-first)

1. Build the policy in the portal (**Communication Compliance** → **Policies** → **Create policy**) or with

`CCFIN-Configuration.ps1 -Commit` (default is `-WhatIf` — it prints what it *would* create and changes nothing until you pass `-Commit`). The script uses the documented `New-SupervisoryReviewPolicyV2` / `New-SupervisoryReviewRule` cmdlets; **verify cmdlet availability in your tenant.**

1. Scope the policy to `FINRA Supervised – Pilot`, exclude `FINRA Excluded – Privacy`, assign reviewers

`FINRA Principals – Pilot`, attach the classifiers, the `FINRA Lexicon – Conduct` dictionary, the sensitive info types, the conditions, and the sampling percentage — the **lexicons** pillar.

1. **Keep it in simulation/test / limited-pilot mode.** Do **not** expand scope beyond the pilot group

yet. If simulation surfaces items, they are **for tuning only** — not yet a live supervisory review.

1. **Pass/fail gate:** the policy exists, is scoped to the pilot (not "everyone"), has the intended

reviewers, classifiers, lexicon, conditions, and sampling, and is confined to the pilot. Confirm with `CCFIN-Validation.ps1`. **Rollback:** disable/delete `FINRA Supervision – Pilot – Simulation` via the portal or `CCFIN-Configuration.ps1 -Remove -Commit` — no supervised communications are affected.

Step 5 — Validate detection with test communications (Pilot / Validate — lexicons)

1. From a **pilot user only**, send test communications that **should** match (sample language matching a

selected classifier and/or a `FINRA Lexicon – Conduct` term) and ordinary communications that should **not**. Allow processing time.

1. Confirm matching items appear for `FINRA Supervision – Pilot – Simulation` and that clean messages do

not — using the portal and `CCFIN-Report.ps1`.

1. **Pass/fail gate:** true positives surface; clean messages don't. **Fail** → tune the lexicon and

classifier/condition selection (Step 8) — never widen scope to compensate.

Step 6 — Exercise the designated-principal review workflow (Pilot / Validate — review)

1. As a **designated principal (Analyst)**, open a surfaced item, examine it **in context**, and apply a

remediation action: **tag** (compliant / questionable / non-compliant), add a **note**, **resolve**, **notify**, or **escalate** to an **Investigator**. This is the Rule 3110 review mechanic.

1. As an **Investigator**, confirm an escalation arrives with context. As a **Viewer**, confirm you see

reports only, no message content.

1. Confirm the **reviewer trail** (who reviewed what, when, with what disposition) is captured — the

defensible-supervision evidence — via `CCFIN-Report.ps1` (`FINRA Supervision Rollup – Evidence`) and the unified audit log.

1. **Pass/fail gate:** a principal can triage end-to-end; escalation reaches an Investigator; a Viewer

sees no content; the reviewer trail is recorded. **Fail** → correct role membership (Step 2). **Determination reminder:** tagging an item is a **supervisory-principal judgment**, not a technical result — the workflow records the judgment, it does not make it.

Step 7 — Configure the immutable retention evidence layer (Configure — evidence)

1. **Only after Compliance/Records approve** the retention period and the immutability decision

(Requirement 2.6), configure a retention policy `FINRA Comms Records – 17a-4` over the supervised communications (Exchange/Teams/Viva Engage as scoped), using `RetentionCompliance*` cmdlets or the portal (**Data Lifecycle Management / Records Management**). `CCFIN-EvidenceCheck.ps1`

reports current coverage read-only.

1. Where the records decision requires **immutability**, apply **Preservation Lock**

(`Set-RetentionCompliancePolicy -Identity 'FINRA Comms Records – 17a-4' -RestrictiveRetention $true`) — this makes the policy **tamper-evident and irreversible: it cannot be disabled, shortened, or deleted**, only made more inclusive.

> ■■ ***Preservation Lock is permanent.*** *Apply it **only** with explicit, written Compliance/Records approval and after the schedule is confirmed.* `CCFIN-EvidenceCheck.ps1` *and* `CCFIN-Configuration.ps1` *require* `-Commit` **and* an explicit lock switch, and refuse to lock by default.*

1. **Pass/fail gate:** the supervised communications are covered by retention for the approved period;

where required, immutability is in effect and verified; review activity is captured in the audit log. **Rollback:** an **unlocked** retention policy can be adjusted/removed under change control; a **locked** one **cannot** — which is why the lock is gated on written approval.

Step 8 — Tune, then expand under change control (Validate → Expand/enforce)

1. Using the pilot results, tune the **lexicon** and **classifier/condition** selection and the

sampling percentage to reduce noise while preserving coverage — re-running Steps 5–6 after each change.

1. When Compliance signs off the pilot, **expand** the supervised scope from `FINRA Supervised – Pilot`

toward the full approved registered population and move the policy from simulation to **active** supervision, in **rings** under change control. Rename/clone to `FINRA Supervision – Production`.

1. Confirm the evidence layer covers the expanded scope, and that reporting (`CCFIN-Report.ps1`) produces

the supervision-activity rollup examiners expect.

1. **Pass/fail gate:** each expansion ring passes the same validation as the pilot; evidence retention

tracks the scope; reporting is complete. **Rollback:** revert a ring by returning its policy to simulation / narrowing scope — **without** touching the (possibly locked) evidence retention.

Rollback summary

Step	Change	Rollback
2	Role/scope/privacy	Remove mistaken membership; reset privacy option (no policy exists yet)
4	Policy in simulation	Disable/delete `FINRA Supervision – Pilot – Simulation`; no comms affected

Step	Change	Rollback
5–6	Lexicon/review tuning	Revert lexicon/classifier/sampling changes
7	Retention (unlocked)	Adjust/remove under change control
7	Retention (**locked**)	**Not reversible** — gated on written Compliance/Records approval
8	Expansion ring	Return ring to simulation / narrow scope; leave evidence retention intact

*Every step defers the **verdict** (is this a violation? what action?) and the **records decision** (period, immutability) to the firm's supervisory principals, Compliance, Records, and Legal. This guide delivers the configured, piloted, validated **mechanism and evidence** — not the determination.*

5. Testing & Validation Guide — Financial / FINRA Communications Compliance (Microsoft Purview)

Run these after configuring the guardrails (Step 2), building the policy in simulation (Steps 4–5), exercising the review workflow (Step 6), and configuring the evidence layer (Step 7) — and again after each tuning change and **before** any expansion. Every test is **safe and read-only or contained to the pilot group**; the point is to prove the three pillars — **lexicons (detection)**, **review (workflow)**, and **evidence (retention/recordkeeping)** — plus **privacy** and **role separation** work before broad rollout. Use test communications inside the `FINRA Supervised – Pilot` population **only**. **Outcomes remain a supervisory-principal / Compliance determination — these tests validate the mechanism, not the verdict.**

Each test states **Do · Expected · On fail**. Record the result of each in the pilot sign-off.

A. Role separation and privacy (guardrails)

Test 1 — Role separation is in place

- **Do:** Run `CCFIN-Discovery.ps1`; review the `FINRA Supervision Roles – Evidence` snapshot.
- **Expected:** Policy-builders (**Admin**) are separated from designated principals (**Analysts**) and investigators (**Investigators**); **Viewers** are oversight-only; **no reviewer supervises themselves**. No one is silently both Admin **and** Analyst/Investigator unless Compliance explicitly accepted it.
- **On fail:** Correct membership (Implementation Step 2) before proceeding.

Test 2 — Privacy option is in effect

- **Do:** Portal → `Settings → Communication Compliance`; confirm the agreed **privacy option** (pseudonymized usernames if required). Open a surfaced item as a reviewer.

• **Expected:** The review experience reflects the agreed setting; the supervised population **excludes**

`FINRA Excluded – Privacy`.

• **On fail:** Set the privacy option / fix scope.

B. Scope (supervised population)

Test 3 — Supervised population is the approved set and exclusions hold

• **Do:** Run `CCFIN-EvidenceCheck.ps1` (or `CCFIN-Report.ps1`) and inspect the policy's supervised

users/groups and exclusions.

• **Expected:** Scope equals the approved `FINRA Supervised – Pilot` (**not "everyone"**); members of

`FINRA Excluded – Privacy` are not supervised.

• **On fail:** Tighten scope (Implementation Step 2).

Test 4 — Policy is correctly composed (lexicons attached)

• **Do:** Run `CCFIN-Validation.ps1`; review the policy/rule inventory for

`FINRA Supervision – Pilot – Simulation` / `FINRA Conduct Rule – Pilot`.

• **Expected:** The policy is scoped to the pilot group, has the intended **designated-principal

reviewers**, the selected** regulated-conduct classifiers**, the** `FINRA Lexicon – Conduct` **dictionary, the sensitive info types, the conditions, and the** risk-based sampling percentage**, and is in** simulation/pilot** mode.

• **On fail:** Correct via `CCFIN-Configuration.ps1` (re-run with `-Commit`).

C. Lexicons (detection)

Test 5 — A regulated-conduct message surfaces (true positive)

• **Do:** From a pilot user, send a test communication that should match a selected classifier and/or a

`FINRA Lexicon – Conduct` term (e.g. a guarantee/"can't lose" phrase or a selling-away term). Allow processing time.

• **Expected:** A matching item appears for the policy in Communication Compliance, visible to the

assigned designated principals.

• **On fail:** Check classifier/lexicon/condition selection and channel coverage.

Test 6 — A clean message does NOT surface (false-positive check)

• **Do:** From a pilot user, send an ordinary, non-violating business message.

• **Expected:** No item is raised.

• **On fail:** Tune the lexicon/classifiers/conditions (Implementation Step 8) — do **not** widen scope.

Test 7 — All in-scope channels are covered

• **Do:** From a pilot user, send matching test content across each in-scope channel (Teams, Exchange, Viva Engage, and any connected source). Confirm data connectors are healthy in the portal.

• **Expected:** Matches surface from each in-scope channel; no in-scope channel is silently missing.

• **On fail:** Fix the missing channel / connector (Requirement 2.5) before expanding.

D. Review (workflow)

Test 8 — A designated principal can work an item end-to-end

• **Do:** As an **Analyst** designated principal, open a surfaced test item; examine it in context; apply a **remediation action** — tag (compliant/questionable/non-compliant), add a note, resolve, notify, or **escalate**.

• **Expected:** The principal can triage and action the item; the action is recorded.

• **On fail:** Check Analysts role membership and reviewer assignment.

Test 9 — Escalation reaches an Investigator; Viewer sees no content

• **Do:** Escalate the test item to an **Investigator**; separately sign in as a **Viewer**.

• **Expected:** The Investigator receives the escalation with context; the Viewer sees reports/dashboards but **no message content**.

• **On fail:** Correct Investigator/Viewer role membership.

Test 10 — The reviewer trail is defensible

• **Do:** Run `CCFIN-Report.ps1` for `FINRA Supervision Rollup – Evidence`; confirm reviewer identity, timestamp, and disposition are captured for the test items, and cross-check the unified audit log.

• **Expected:** Who reviewed what, when, and with what disposition is recorded — the reasonable-supervision evidence.

• **On fail:** Confirm auditing is enabled and reviewer actions are being logged.

E. Evidence (retention / recordkeeping)

Test 11 — Supervised communications are retained for the approved period

• **Do:** Run `CCFIN-EvidenceCheck.ps1`; review coverage of `FINRA Comms Records – 17a-4` against the supervised scope.

• **Expected:** The supervised communications are covered by retention for the **Compliance/Records-approved** period across the in-scope workloads.

• **On fail:** Extend retention coverage (Implementation Step 7) under Compliance/Records approval.

Test 12 — Immutability is in effect where required (tamper-evident)

• **Do:** Run `CCFIN-EvidenceCheck.ps1`; check whether `FINRA Comms Records – 17a-4` has **Preservation Lock** (`RestrictiveRetention`) where the records decision requires it.

• **Expected:** Where required, the retention policy is **locked** (cannot be shortened/disabled/deleted) and the tool reports it as immutable. Where **not** required, it is intentionally unlocked.

• **On fail:** If the records decision requires immutability and it is missing, apply the lock **only** with written Compliance/Records approval (Step 7); **never** apply it to satisfy a test.

Test 13 — Report pack is examiner-ready

• **Do:** Run `CCFIN-Report.ps1` to produce the supervision-activity rollup and the policy/role/retention inventory.

• **Expected:** A coherent evidence pack — policy configuration, role separation, supervised scope, review activity, and retention/immutability status — suitable to demonstrate the program.

• **On fail:** Resolve the missing element and re-run.

Pilot exit criteria (all must pass before expansion)

1. Role separation and privacy in effect (Tests 1–2).
2. Supervised scope is the approved set; exclusions hold (Tests 3–4).
3. True positives surface; clean messages don't; all in-scope channels covered (Tests 5–7).
4. Designated-principal review, escalation, and Viewer-no-content all work; reviewer trail is defensible (Tests 8–10).
1. Evidence retention covers the approved period; immutability is in effect where required; the report pack is examiner-ready (Tests 11–13).

*Passing these validates the **mechanism and the evidence**. Whether any surfaced communication is a **violation**, and what **action** follows, remain determinations for the firm's designated supervisory principals, Compliance, and Legal.*

6. Troubleshooting Guide — Financial / FINRA Communications Compliance (Microsoft Purview)

Issues are grouped by symptom. Each gives the **likely cause** and **what to do**. Purview features are **licensing-/plan-dependent and some are in preview**, and the portal evolves — where a path/cmdlet isn't where this guide says, **verify against your current tenant.** None of these fixes changes who owns the **determination**: the verdict on a communication and the retention/immutability decision remain with the firm's supervisory principals, Compliance, Records, and Legal.

A. Entitlement, portal, and classifiers

Communication Compliance area isn't visible / policies won't create.

- *Cause:* Missing entitlement (E5 / E5 Compliance) or insufficient role (Requirements 2.1–2.2).
- *Do:* Confirm the entitlement with Microsoft licensing (not just portal visibility); confirm you hold

a Communication Compliance role. Assign licensing/role under change control, then retry.

A regulated-conduct classifier isn't available to select.

- *Cause:* Classifier is plan-gated or **in preview** in your tenant, or not yet provisioned.
- *Do:* Verify the specific classifier's availability for your licensing; treat *preview* classifiers as

a Compliance risk decision before relying on them. Proceed with the available classifiers plus the `FINRA Lexicon – Conduct` dictionary and revisit when the classifier is GA.

`Get-SupervisoryReviewPolicyV2` **/** `New-SupervisoryReviewRule` **not recognized.**

- *Cause:* Not connected to Security & Compliance PowerShell, wrong module, or the cmdlet set differs in

your tenant version.

- *Do:* `Connect-IPPSSession` with a modern-auth admin (GR §3). If a cmdlet/parameter name differs,

complete that step in the portal and use the scripts for the read-only checks — cmdlet surface for Communication Compliance varies by tenant; **verify, don't assume.**

B. Role separation

`CCFIN-Discovery.ps1` **warns an identity is both builder and reviewer.**

- *Cause:* Someone is in **Communication Compliance Admin** *and* **Analysts/Investigators**, or the

combined **Communication Compliance** role group is in use (Requirement 2.2).

- *Do:* Remove the overlapping membership (Implementation Step 2) unless Compliance/Legal explicitly

accepted it. Never let a reviewer supervise themselves. Re-run Discovery to confirm the snapshot.

Reviewers can't open items / see the review queue.

- *Cause:* The designated principals aren't in **Communication Compliance Analysts**, or aren't assigned

as the policy's reviewers.

- *Do:* Add them to Analysts and set them as reviewers on the policy (Steps 2, 4). Confirm with

`CCFIN-Validation.ps1` (“Policy has designated reviewers”).

A Viewer can see message content.

- *Cause:* The person is in a content-bearing role (Analyst/Investigator), not **Viewers**.
- *Do:* Correct role membership — Viewers get reports/dashboards only, no content (Step 6, Test 9).

C. Scope and privacy

`CCFIN-EvidenceCheck.ps1` **flags scope as over-broad/empty.**

- *Cause:* The policy is scoped to "everyone" or has no supervised users (Requirement 2.3).
- *Do:* Scope to the approved `FINRA Supervised – Pilot` (registered population) and apply the `FINRA Excluded – Privacy` exclusion (Step 2). Scope is a Compliance determination — get it confirmed.

Usernames aren't pseudonymized in review (privacy requirement).

- *Cause:* The privacy option isn't set (Requirement 2.7).
- *Do:* `Settings` → `Communication Compliance` → enable pseudonymized usernames; don't run live without Privacy/Legal sign-off on the lawful basis (Test 2).

D. Detection (lexicons)

A message that should match doesn't surface (false negative).

- *Cause:* Classifier/lexicon/condition not attached, sampling too low, the channel isn't covered, or processing latency.
- *Do:* Allow processing time; confirm the classifier and `FINRA Lexicon – Conduct` are attached (`CCFIN-Validation.ps1`, Test 4); raise the risk-based sampling if the WSPs allow; verify the channel (Test 7). Don't widen the *population* to compensate.

Clean messages surface constantly (false positives / reviewer overload).

- *Cause:* Lexicon too broad, classifier too aggressive, sampling too high.
- *Do:* Tune the lexicon terms and conditions and right-size sampling to reviewer capacity (Implementation Step 8); re-run Tests 5–6 after each change. Keep the lexicon Compliance-owned.

A channel registered persons use (e.g. text/IM) isn't monitored.

- *Cause:* The data connector for that source isn't configured/healthy (Requirement 2.5).
- *Do:* `Data connectors` → stand up/repair the connector and confirm data is flowing before treating that channel as supervised. An omitted channel is a known examination finding.

E. Review workflow

No review activity / reviewer trail appears in `CCFIN-Report.ps1`.

- *Cause:* No items yet (fresh pilot), auditing not enabled, or `Get-SupervisoryReviewActivity` unavailable in your tenant.
- *Do:* Generate a pilot test item (Test 5); confirm unified auditing is on; if the activity cmdlet is unavailable, use `Search-UnifiedAuditLog -RecordType ComplianceSupervisionExchange` and the portal Reports (the report script prints this fallback).

Escalation to an Investigator doesn't arrive.

- *Cause:* No one in **Communication Compliance Investigators**, or escalation not configured.
- *Do:* Populate Investigators and confirm the escalation action (Step 6, Test 8).

Review backlog is growing.

- *Cause:* Sampling exceeds reviewer capacity, or too few designated principals.
- *Do:* Right-size sampling to the WSP-defined capacity and/or add principals; a backlog of unreviewed

items is a supervision gap (Best Practices → Review workflow).

F. Evidence (retention / immutability)

`CCFIN-EvidenceCheck.ps1` **reports no evidence-retention policy.**

- *Cause:* The evidence layer isn't configured (Requirement 2.6, Step 7).
- *Do:* Create `FINRA Comms Records – 17a-4` over the supervised comms with the **Compliance/Records-

approved** period. Do not lock yet.

Immutability required but retention isn't locked.

- *Cause:* Preservation Lock not applied.
- *Do:* Apply the lock **only** with written Compliance/Records approval:

`Set-RetentionCompliancePolicy -Identity 'FINRA Comms Records – 17a-4' -RestrictiveRetention $true` (or `CCFIN-Configuration.ps1 -ConfigureRetention -ApplyPreservationLock -Commit`). **It is irreversible** — a locked policy can only be broadened, never shortened, disabled, or deleted.

We locked the wrong policy / need to shorten a locked policy.

- *Cause:* Preservation Lock was applied prematurely.
- *Do:* You **cannot** reverse it. This is why the lock is gated on written approval and the scripts

refuse to lock by default. Escalate to Compliance/Records/Legal; the only forward path is to broaden or supersede, not shorten.

Detection scope expanded but evidence retention didn't follow.

- *Cause:* Retention scope wasn't extended when supervision expanded (Step 8).
- *Do:* Extend the evidence retention to match the new supervised scope under Compliance/Records

approval — supervising a channel you don't preserve is a recordkeeping gap.

When to stop and escalate

- Any question of **whether a communication is a violation**, **which rule applies**, the **retention

period**, or** whether to apply an irreversible lock → **stop and route to the firm's designated supervisory principals, Compliance, Records, or Legal. These are** determinations**, not technical fixes. This solution provides the method and the evidence; the verdict and the records decision are theirs.

7. Best Practices — Financial / FINRA Communications Compliance (Microsoft Purview)

Operating guidance for a defensible, examinable communications-supervision program. These practices sit on top of the shared Purview category requirements and the Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand model. **None of them changes who owns the determination:** what constitutes a violation, which rules apply, the retention schedule, and any supervisory/disciplinary action are **Compliance, Records, Legal, and designated-supervisory-principal** decisions.

Program design

• **Anchor everything to the WSPs.** The Written Supervisory Procedures are the authority for *who* is

supervised, *what* is reviewed, at *what sampling rate*, and *by whom*. Configure Purview to the WSPs; if the tool can't express a WSP requirement, fix the WSP or the design — don't quietly diverge.

• **Treat the three pillars as one program.** Lexicons without review produce alerts nobody actions;

review without evidence isn't defensible; evidence without detection preserves noise. Keep detection, the designated-principal workflow, and immutable retention in lockstep.

• **Scope to the registered/covered population, not "everyone."** Over-scoping is a privacy and

employment/works-council risk and dilutes reviewer attention; under-scoping is a supervision gap. Re-confirm the population with Compliance on a schedule as people change roles.

Role separation and privacy

• **Separate builders, reviewers, investigators, and oversight** using the four Communication Compliance

role groups; **never let a reviewer supervise themselves.** Avoid the combined role group outside a tiny pilot.

• **Make separation evidence-able.** Run `CCFIN-Discovery.ps1` on a schedule and keep the

`FINRA Supervision Roles – Evidence` snapshot; separation you can't demonstrate is separation you don't have.

• **Configure privacy before the first policy runs.** Use pseudonymized usernames where Privacy/Legal or

a works council requires it, and confirm a documented lawful basis/notice. Reviewer over-reach is itself a compliance and trust risk.

Lexicons and detection tuning

• **Start narrow and tune down noise, not up.** Begin with the highest-value classifiers and a focused

`FINRA Lexicon – Conduct`, then refine conditions and sampling. Widening scope to "catch more" without tuning buries reviewers and degrades the program.

- **Keep the lexicon a living, Compliance-owned artifact.** Guarantees, selling-away, outside-business,

and complaint language evolve; review the term lists with Compliance periodically and version them.

- **Verify classifier availability — don't assume.** Regulated-conduct trainable classifiers are

plan-dependent and **some are in preview**; confirm each in your tenant and flag preview classifiers to Compliance for a risk decision before relying on them.

- **Right-size the sampling rate to reviewer capacity** as set by the WSPs. A rate the principals can't

actually keep up with is a supervision gap on paper *and* in practice.

Review workflow

- **Make the reviewer trail complete and timely.** Disposition (compliant/questionable/non-compliant),

notes, escalations, and resolution are the reasonable-supervision evidence; a backlog of unreviewed items is a finding. Monitor queue age.

- **Escalate to Investigators, decide with Compliance/Legal.** Principals surface and disposition;

genuine potential violations go to Investigators and then to Compliance/Legal for the determination and any action. Keep that handoff explicit.

- **Coach on context.** Train principals to review flagged messages **in thread context**, not in

isolation — a keyword match is a prompt to look, not a verdict.

Evidence and recordkeeping

- **Get the records decision in writing before touching retention.** The period and whether to apply

Preservation Lock are Compliance/Records decisions. **Preservation Lock is irreversible** — a locked policy cannot be shortened, disabled, or deleted, only broadened.

- **Pilot retention unlocked, lock deliberately.** Validate coverage with an **unlocked** policy first;

apply the lock only once the schedule is confirmed and approved. The scripts refuse to lock by default and require an explicit switch plus `-Commit`.

- **Keep detection scope and evidence scope aligned.** When you expand supervision, extend the evidence

retention to match — supervising a channel you don't preserve is a recordkeeping gap.

- **Preserve the supervision *and* the review activity.** Both the underlying communications and the

fact/record of review are examinable; ensure auditing is on and the activity rollup is retained.

Change control and rollout

- **Always pilot in simulation/test first.** Supervision and retention are high-impact; never enable

firm-wide blind. Expand in rings, re-validating each with the full test set.

• **Rollback plan per stage — and know what can't roll back.** Role/scope/policy changes and *unlocked*

retention are reversible; a *locked* retention policy is not. Gate the lock on written approval precisely because it's one-way.

• **Re-validate after every change.** Re-run the Testing guide after tuning, after adding a channel, and

before each expansion ring. Keep the results as pilot/expansion sign-off evidence.

Operations

• **Schedule the read-only tools.** Run `CCFIN-Discovery.ps1`, `CCFIN-Validation.ps1`,

`CCFIN-EvidenceCheck.ps1`, and `CCFIN-Report.ps1` on a cadence to catch drift (separation collapse, scope creep, retention gaps, review backlog) early.

• **No credentials in code or automation.** The scripts use interactive/modern-auth

`Connect-IPPSSession` / `Connect-MgGraph`; keep secrets out of scripts, scheduled tasks, and logs.

• **Review the program with Compliance on a fixed cadence** — lexicon terms, sampling, population,

channels, and retention schedule — and record the review. A supervision program is examined on whether it is *maintained*, not just whether it was once configured.

Bottom line: keep the three pillars in lockstep, keep separation and evidence demonstrable, pilot every change in simulation, and leave every verdict and records decision with Compliance, Records, Legal, and the firm's designated supervisory principals.

8. Deliverables Summary — Financial / FINRA Communications Compliance (Microsoft Purview)

What this solution delivers

A complete, repeatable way to stand up a **FINRA/SEC-aligned communications-supervision program** in Microsoft Purview Communication Compliance — organized around three pillars: **lexicons** (regulated-conduct detection), **review** (a designated-principal, risk-based-sample supervisory workflow), and **evidence** (immutable communications retention and examiner-ready reporting) — configured, piloted in **simulation/test**, validated with pass/fail gates, and expanded under change control.

Documents

#	Document	What it covers
1	**Solution Overview**	What the program is, the three pillars, how it works, scope/boundaries, and how it differs from general Communication Compliance

#	Document	What it covers
2	**Requirements Guide**	Solution-specific prerequisites (entitlement, designated principals + separation, supervised population, firm lexicons + WSPs, channels/connectors, retention + immutability decision, privacy, change control) — on top of the six category requirements
3	**Implementation Guide**	Ordered steps: guardrails first, design from WSPs/lexicons, build in simulation, validate detection + review, configure immutable evidence retention, tune, expand — each artifact named, with pass/fail gates + rollback
5	**Testing & Validation Guide**	13 safe/read-only or pilot-contained tests across role separation, privacy, scope, lexicons, review workflow, and evidence; pilot exit criteria
6	**Troubleshooting Guide**	Common issues by symptom — entitlement/classifier availability, separation, scope, detection, review workflow, connectors, and retention/immutability
7	**Best Practices**	Program design, role separation/privacy, lexicon tuning, review workflow, evidence/recordkeeping, change control, operations
—	**Executive Summary**	One-page business framing for decision-makers

PowerShell tools (5)

All are **read-only or `-WhatIf` by default**; writes are gated behind `-Commit`, and the irreversible retention **Preservation Lock** requires an additional explicit switch. **No credentials in code** — they use interactive modern-auth `Connect-IPPSSession` / `Connect-MgGraph`. Cmdlet and classifier availability is **plan-dependent — verify in your tenant.**

Script	Purpose	Default mode
`CCFIN-Discovery.ps1`	Readiness + role-separation snapshot + existing policies/retention/privacy signals (`FINRA Supervision Roles – Evidence`)	Read-only
`CCFIN-Configuration.ps1`	Create/update the supervisory-review policy + rule in **simulation** (lexicons/classifiers/scope/reviewers/sampling); optional evidence-retention config	`-WhatIf` (needs `-Commit`; lock needs an extra switch)
`CCFIN-Validation.ps1`	Pass/fail checks: separation, policy scope/composition, reviewers, retention/immutability presence	Read-only
`CCFIN-Report.ps1`	Supervision-activity rollup + policy/role/retention inventory (`FINRA Supervision Rollup – Evidence`)	Read-only
`CCFIN-EvidenceCheck.ps1`	Scope + evidence health helper: supervised/excluded scope and immutable-retention (17a-4) coverage	Read-only

Named artifacts created/used

`FINRA Supervised – Pilot`, `FINRA Excluded – Privacy`, `FINRA Principals – Pilot`, `FINRA Lexicon – Conduct`, `FINRA Supervision – Pilot – Simulation`, `FINRA Conduct Rule – Pilot`, `FINRA Comms Records – 17a-4`, `FINRA Supervision Roles – Evidence`, `FINRA Supervision Rollup – Evidence`.

Definition of done

- Role separation, privacy, and the approved supervised scope are configured and demonstrable.
- The supervisory-review policy runs in **simulation**, surfaces true positives, and suppresses noise across all in-scope channels.
- Designated principals can review end-to-end; escalation and Viewer-no-content work; the reviewer trail is defensible.
- Immutable communications retention is in effect for the Compliance/Records-approved period where required; reporting is examiner-ready.
- All 13 tests pass; expansion proceeds in rings under change control.

Explicitly deferred (not in this solution)

The **regulatory determination** (which rules apply, whether a communication violates them), the **retention schedule and immutability decision**, and any **supervisory or disciplinary action** are owned by the

firm's **designated supervisory principals, Compliance, Records, and Legal**. Trade/order surveillance and third-party archiving products are separate disciplines. This solution delivers the **technical supervision-and-evidence mechanism**, configured, piloted, and validated.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CCFIN-Configuration.ps1

CCFIN-Discovery.ps1

CCFIN-EvidenceCheck.ps1

CCFIN-Report.ps1

CCFIN-Validation.ps1